Metodologia di redazione Piano Sicurezza

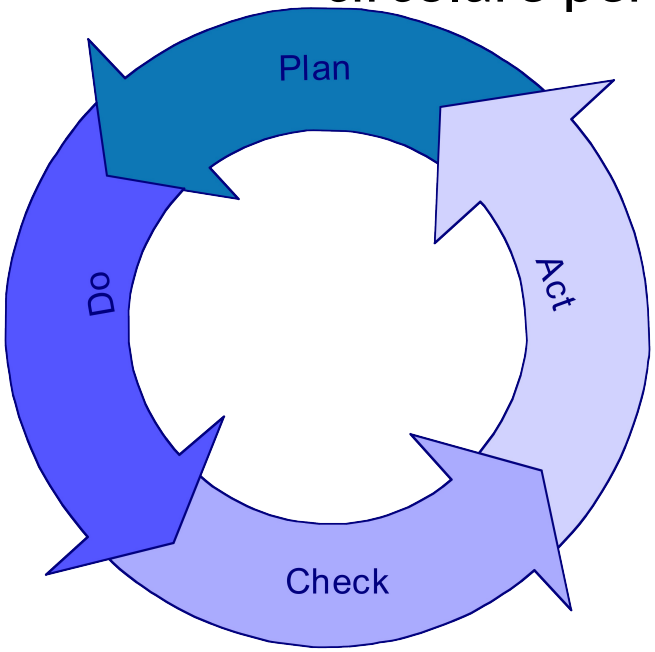
Franco Arcieri

Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l'attuazione del Piano

- Metodologia utilizzata per l'attuazione del Piano di sicurezza

Metodologia PDCA metodologia che partendo da un'idea (**P**lan **D**o **C**heck **A**ct) di fondo, la sviluppa in modo circolare per verificarne i presupposti



Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l'attuazione del Piano

- Metodologia PDCA (**P**lan, **D**o, **C**heck, **A**ct):

  - **PLAN** Identificazione del problema, nella sua analisi, nell'individuazione delle cause reali, nonchè nella definizione e pianificazione delle azioni correttive.
  - **DO** Preparazione ed applicazione delle azioni pianificate.
  - **CHECK** Verifica dei i risultati raggiunti a fronte degli obiettivi attesi.
  - **ACT** Consolidamento dei risultati raggiunti, oppure nell'attivazione di un nuovo ciclo PDCA, con l'introduzione di opportuni correttivi, se non sono stati raggiunti i risultati attesi.

Definizione di Piano di Sicurezza

- Piano di intervento mirato alla riduzione del livello di rischio, o al suo mantenimento se considerato residuo.
- Documento dinamico che deve essere aggiornato:
  - Al variare della struttura organizzativa di riferimento
  - Al variare del contesto di riferimento
  - Al variare delle soluzioni tecnologiche utilizzate ed al livello di sicurezza delle stesse
  - Al variare delle minacce e delle vulnerabilità
  - Al verificarsi di eventi negativi che ne hanno compromesso o meno l’efficacia
- Documento altamente riservato

Definizione di Piano di Sicurezza

- Obiettivi:
  - Definizione “Sistema di Gestione” che permette di tenere sotto controllo nel tempo i processi legati alla sicurezza, tramite la definizione di ruoli, responsabilità, di procedure formali e di canali di comunicazione.
  - Salvaguardia delle informazioni: è fondamentale individuare quali informazioni proteggere, quale livello di protezione assegnare a ciascuna di esse e quali azioni condurre per gestirne la sicurezza rispetto ai fattori dati.

Definizione di Piano di Sicurezza

- Che cosa si intende per “sicurezza” delle informazioni?
  - L’insieme delle misure atte a garantire la disponibilità, l’integrità e la riservatezza delle informazioni gestite
  - **Disponibilità**: le informazioni sono rese disponibili quando occorre e nell’ambito di un contesto pertinente.
  - **Integrità**: protezione contro alterazioni o danneggiamenti; tutela dell’accuratezza e completezza dei dati.
  - **Riservatezza**: solo gli utenti autorizzati possono accedere alle informazioni necessarie

Normative sulla sicurezza

- Panorama delle norme
  - Norme **funzionali** relative ai prodotti, aventi come scopo principale la ricerca della interoperabilità dei sistemi informatici
  - Criteri di **valutazione** dell’assurance, ossia della fiducia riponibile nella sicurezza realizzata da sistemi e prodotti informatici
  - Norme relative al **sistema di gestione** della sicurezza nell’azienda
  - Norme **legali** nazionali ed internazionali

Normative sulla sicurezza

- Norme **funzionali** relative ai prodotti
  - I protocolli di comunicazione
  - Il formato dei dati sulle smart card (ISO TC 168)
  - Ecc.

Normative sulla sicurezza

- Criteri di **valutazione** dell’assurance
  - TCSEC (Applicato in USA) 1985
  - IT SEC (Applicato in Europa) 1991
  - ISO/IEC 15408 (Common Criteria – evoluzione ed integrazione di entrambi) 1999

Normative sulla sicurezza

- Norme relative al **sistema di gestione** della sicurezza nell'azienda
  - ISO 9000 (solo di riflesso – Analisi del rischio)
  - ISO/IEC TR 13335 (parti 1,2,3,4,5)
  - BS 7799:1 – Code of practice
  - BS 7799-2:2002 – Verifica
  - ISO/IEC 17799:2000 (che recepisce la parte 1 delle BS7799)
  - ISO 27001

Normative sulla sicurezza

- Norme **legali (1/3)**
  - Raccomandazione del Consiglio dell'Unione Europea - 95/144/CE- 7 aprile 1995: applicazione dei criteri per la valutazione della sicurezza della tecnologia dell'informazione
  - Legge 675/96
  - DPR 513/97: regolamento recante criteri e modalità per la formazione, l'archiviazione e la trasmissione di documenti con strumenti informatici e telematici, a norma dell'articolo 15, comma 2, della legge 15 marzo 1997, n. 59,
  - DPCM 22 ottobre 1999 n. 437: regolamento recante caratteristiche e modalità per il rilascio della carta di identità elettronica e del documento di identità elettronico, a norma dell'articolo 2, comma 10, della legge 15 maggio 1997, n. 127, come modificato dall'articolo 2, comma 4, della legge 16 giugno 1998, N. 191.

Normative sulla sicurezza

- Norme **legali (2/3)**
  - DPR 318/99
  - Risoluzione del Consiglio dell'Unione Europea del 6 dicembre 2001: approccio comune nel settore della sicurezza delle reti e dell'informazione.
  - Dlgs. 28 dicembre 2001, n, 467, che indica le “Disposizioni correttive ed integrative della normativa in materia di protezione dei dati personali, a norma dell'articolo 1 della legge 24 marzo 2001, n. 127”
  - Direttiva (denominata direttiva Stanca) 16 gennaio 2002 del Dipartimento per l'innovazione e le tecnologie, sulla sicurezza informatica e delle telecomunicazioni nelle pubbliche amministrazioni;
  - Decreto del Ministro dell'Interno in data 23 aprile 2002, costituzione , presso la Direzione Centrale per i Servizi Demografici il Centro Nazionale Servizi Demografici
  - DPCM 11 aprile 2002 (Schema Nazionale per la valutazione e la certificazione della sicurezza delle tecnologie dell’informazione, ai fini della tutela delle informazioni classificate, concernenti la sicurezza interna ed esterna dello Stato)
  - Altre direttive europee e internazionali (es. Linee guida dell’OCSE – 25 luglio 2002)

Normative sulla sicurezza

- Norme **legali (3/3)**
  - Decreto interministeriale del 24 luglio 2002 per la istituzione del “Comitato tecnico nazionale sulla sicurezza informatica e delle telecomunicazioni nelle pubbliche amministrazioni
  - Direttiva del Ministro Stanca 9 dicembre 2002 “Trasparenza dell’azione amministrativa e gestione elettronica dei flussi documentali”.
  - DPCM 30 ottobre 2003 (schema nazionale per la valutazione e la certificazione della sicurezza nel settore della tecnologia dell'informazione)
  - D.lgs 196/03
  - Comitato tecnico nazionale sulla sicurezza informatica e delle telecomunicazioni nelle pubbliche amministrazioni: “Proposte concernenti le strategie in materia di sicurezza informatica e delle telecomunicazioni per la pubblica amministrazione”, marzo 2004.
  - Legge 43/2005
  - Decreto legge 31 marzo 2005 n. 44 convertito nella legge 31 maggio 2005 n. 88
  - Altre leggi italiane (Cod. Civile e Cod. Penale)
  - Regole tecniche e di sicurezza per l’accesso ai domini applicativi del CNSD

Standard per la sicurezza: le ISO 27001

- Standard ISO 27001:

  affronta il problema sicurezza ad alto livello, indipendentemente dalla tecnologia, concentrandosi principalmente sulla gestione della sicurezza.

  La metodologia ISO 27001 si articola nelle seguenti fasi principali:

  - politiche generali di sicurezza delle informazioni;
  - analisi conoscitiva dell’organizzazione;
  - analisi e gestione del rischio.

Standard per la sicurezza

I dieci capitoli in cui sono raccolte le 127 linee guida per la sicurezza sono:

- Politica di sicurezza.
- Organizzazione per la sicurezza.
- Controllo e classificazione delle risorse.
- Sicurezza del personale.
- Sicurezza materiale e ambientale.
- Gestione operativa e comunicazione.
- Controllo degli accessi.
- Sviluppo e manutenzione dei sistemi.
- Gestione della continuità delle attività.
- Conformità.

Standard per la sicurezza

Il Rischio

probabilità che una **minaccia** nei confronti di un **bene** si attui sfruttando una **vulnerabilità** del sistema

$$R = f(I,T,V)$$

- Impatto: effetto di una azione
- Minaccia: potenziali azioni dannose
- Vulnerabilità: rappresentano una misura del grado di esposizione al rischio del sistema

Standard per la sicurezza

- Effetti degli impatti sulle informazioni
  - Distruzione
  - Modifica
  - Sospensione del servizio (denial of service)

Standard per la sicurezza

- Individuazione degli asset aziendali
- Valutazione degli asset aziendali
  - Dati
  - Elementi fisici
  - Applicazioni software
- Valutazione delle minacce e delle vulnerabilità

Standard per la sicurezza

SGSI

Sistema di Gestione della Sicurezza delle Informazioni

<u>Struttura</u>

1. Definizione delle politiche di sicurezza aziendali
2. Definizione dell’ambito di applicazione del SGSI
3. Analisi del rischio
4. Gestione del rischio
5. Selezione degli strumenti di gestione
6. Stesura della dichiarazione di applicabilità

Standard per la sicurezza

Esempi di utilizzo di SGSI

- In condizioni di normale operatività
- A fronte di atti dolosi
- In presenza di eventi calamitosi

implementazione di un Sistema di Gestione della Sicurezza delle Informazioni

- 1.Politica di sicurezza
- 2.Organizzazione per la sicurezza
- 3.Controllo e classificazione delle risorse
- 4.Sicurezza del personale
- 5.Sicurezza materiale e ambientale
- 6.Gestione operativa e comunicazione
- 7.Controllo degli accessi
- 8.Sviluppo e manutenzione dei sistemi
- 9.Gestione della business continuity
- 10.Conformità

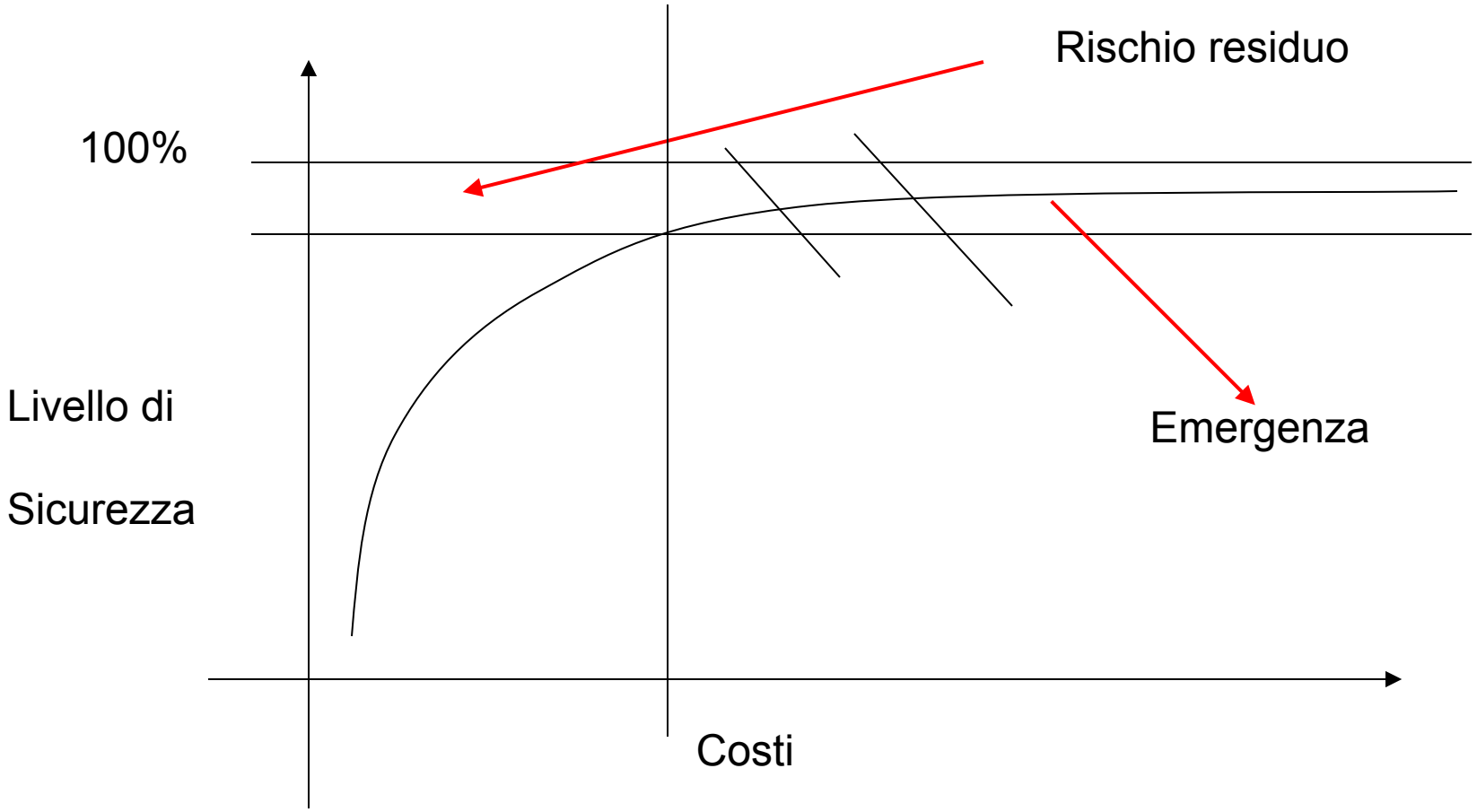
Standard per la sicurezza

Risk Management

Prima	Prevenzione ▪Protezioni ▪Disincentivazione
Durante	Contrasto ▪Rilevamento ▪Filtro
Dopo	Recupero ▪Restore ▪Indagini

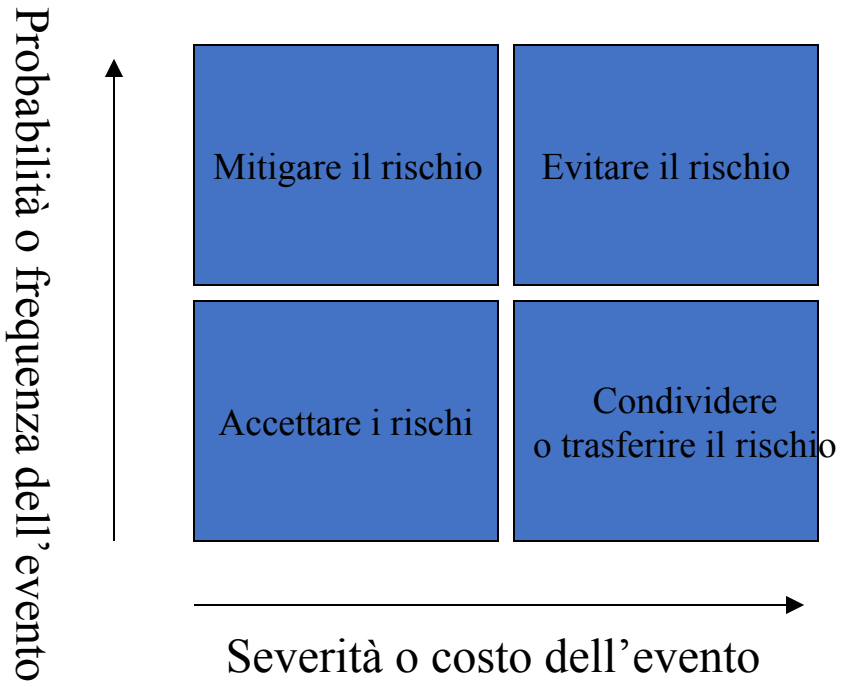
Standard per la sicurezza

Costi della sicurezza



Standard per la sicurezza

Gestione del Rischio



Struttura e contenuti del Piano di Sicurezza CIE (Carta Identità Elettronica)

Ottobre 2005 – Franco Arcieri
Università degli studi di Roma
“Tor Vergata”

Struttura e contenuti Piano di Sicurezza CIE

Centro Nazionale Servizi Demografici (CNSD)

- Centro Nazionale Servizi Demografici (CNSD):
  - costituito, presso la Direzione Centrale per i Servizi Demografici, Con decreto del Ministro dell'Interno in data 23 aprile 2002
  - Il Centro Nazionale nasce come conseguenza logico-normativa degli interventi legislativi svolti negli ultimi anni in materia di AIRE, di CIE, di INA e, non ultimo, di Stato Civile.
  - Al CNSD è affidata, tra gli altri incarichi, la gestione unitaria delle attività e delle infrastrutture informatiche centrali relative al rilascio della Carta d'identità elettronica e alla sua utilizzazione per l'accesso ai servizi erogati dalle Amministrazioni Pubbliche centrali e locali.
- Obiettivo del CNSD:
  - Gestire unitariamente l'attività di tutte le attuali infrastrutture informatiche centrali di interesse dei Servizi demografici, e di quelle in via di realizzazione, al fine di garantire la trasparenza e la sicurezza dei processi di autenticazione e di convalida dei dati anagrafici.

Struttura e contenuti Piano di Sicurezza CIE

Centro Nazionale Servizi Demografici (CNSD)

- Infrastrutture di sicurezza del CNSD:

  Il CNSD e, a livello locale, i Comuni, si avvalgono delle seguenti infrastrutture di sicurezza:
  - Backbone di Sicurezza del CNSD e Porta di accesso ai domini applicativi del CNSD presente presso l'infrastruttura Comunale.
  - Sistema di Sicurezza del Circuito di Emissione delle carte d'identità e dei documenti d'identità elettronici.

  La Porta di accesso ai domini applicativi del CNSD rappresenta il punto di presa in carico delle comunicazioni provenienti dal comune (aggiornamento INA, flussi di emissione della CIE, altri servizi anagrafici del CNSD) e del loro successivo inoltro al CNSD. Tale porta di accesso certifica il punto di origine delle comunicazioni, individuando univocamente il Comune che comunica con il CNSD: **tutte le comunicazioni devono quindi avvenire tramite la Porta di accesso ai domini applicativi del CNSD**.

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Ambito di riferimento del Piano di Sicurezza CIE

  Macroprocessi inerenti l’emissione e l’uso della CIE:

  - Macroprocesso di Caricamento INA
  - Macroprocesso di emissione della CIE
  - Macroprocesso di uso della CIE

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di caricamento dell’INA (Indice Nazionale delle Anagrafi)

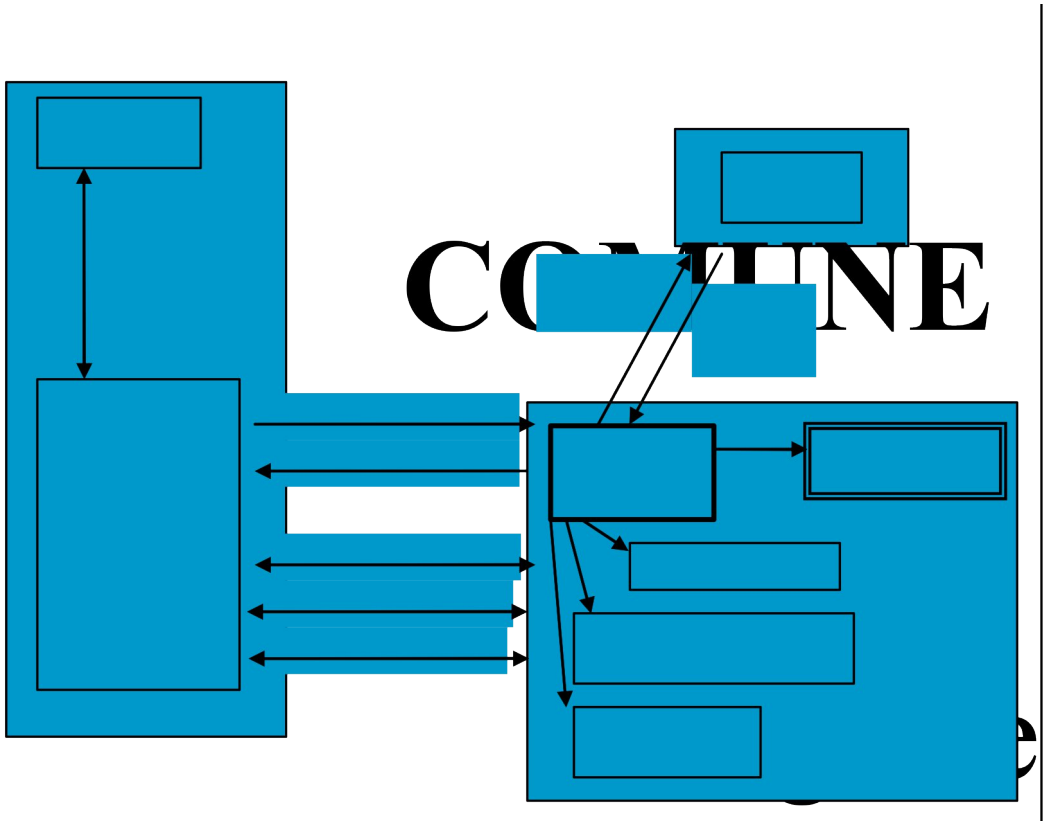
  Processi:

  - Predisposizione Porta di Accesso ai domini Applicativi del CNSD
  - Allineamento dei codici fiscali con gli archivi dell’Anagrafe Tributaria
  - Primo caricamento dell’Indice Nazionale delle Anagrafi
  - Aggiornamento continuo dell’Indice Nazionale delle Anagrafi.

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di caricamento INA – Schema logico



Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

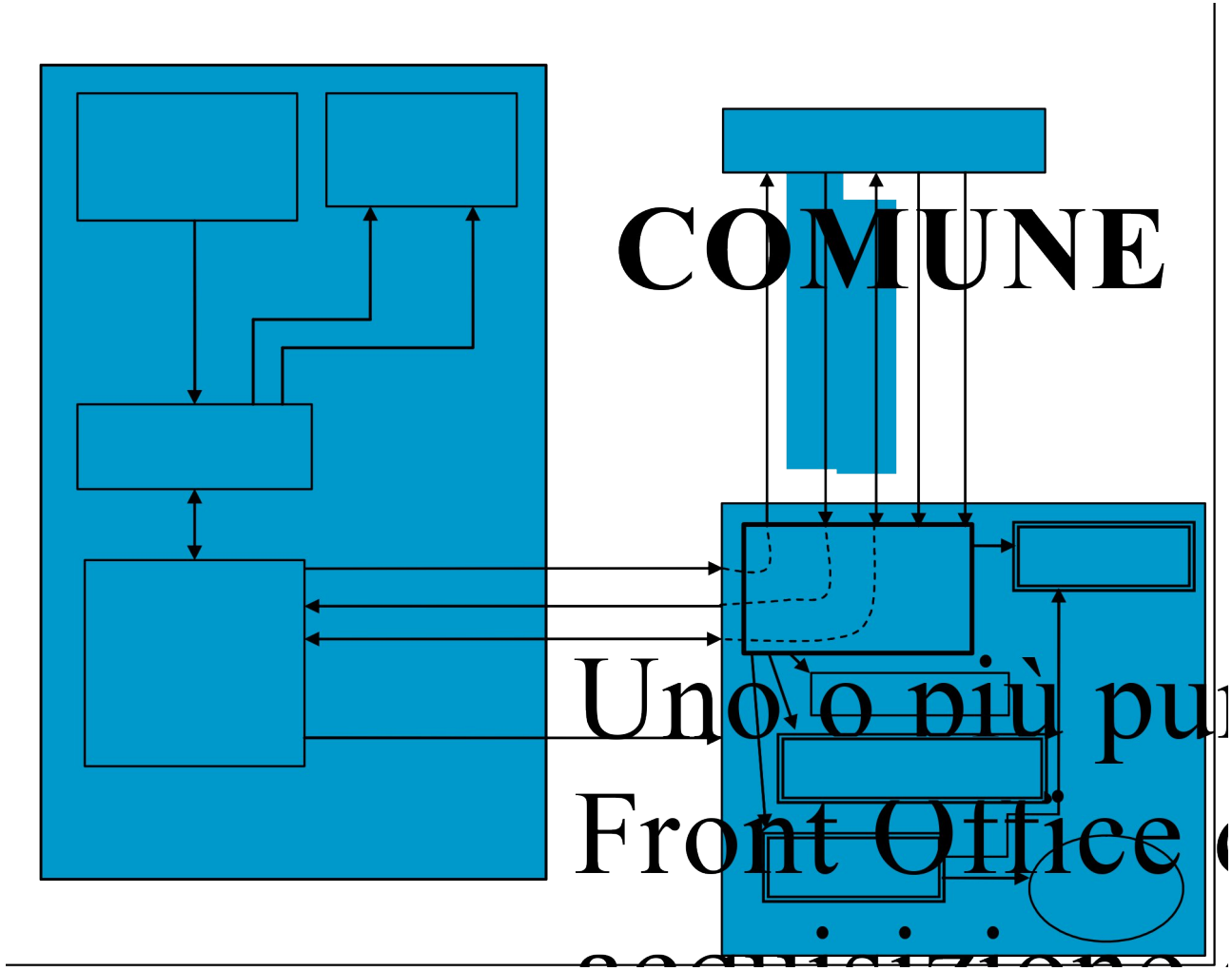
- Macroprocesso di emissione CIE

  Processi:
  - Predisposizione delle Postazioni di Emissione.
  - Acquisizione delle quantità di sicurezza.
  - Acquisizione delle CIE inizializzate dall'Istituto Poligrafico.
  - Rilascio CIE ai cittadini:
    - Richiesta emissione CIE.
    - Acquisizione autorizzazione di emissione CIE e stampa della CIE.
    - Attivazione CIE.
    - Rilascio al cittadino.

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di emissione CIE – Schema logico



Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di emissione CIE

  Il modello organizzativo sul quale si cala l'architettura logica esposta, può variare in base alla realtà organizzativa, logistica e tecnica dei singoli comuni. In particolare si evidenzia che:

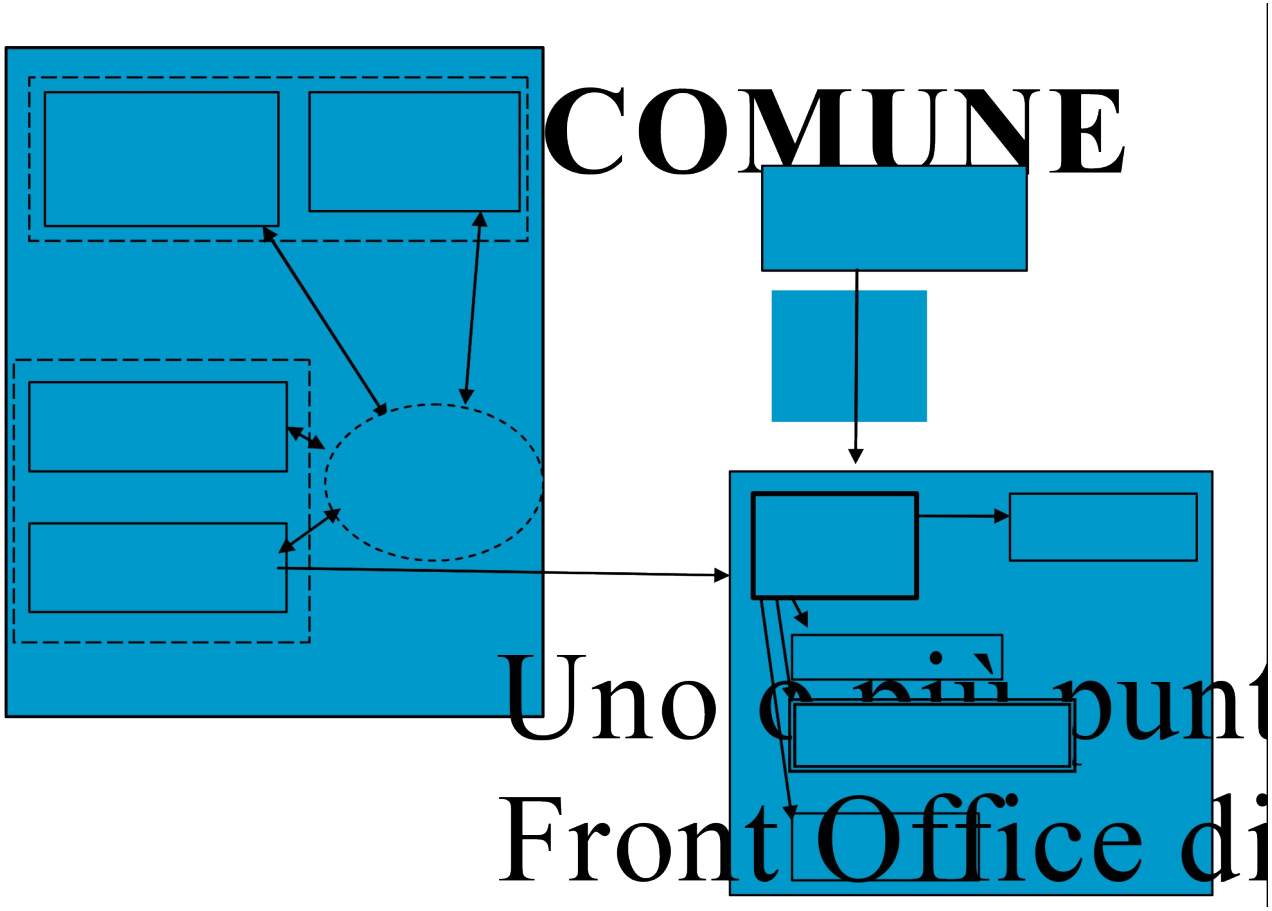
  - può variare il numero dei punti sia di front office per l'acquisizione dei dati ed il rilascio delle CIE, che di back office per l'allestimento e la stampa delle CIE;
  - tutte le comunicazioni con il CNSD devono passare per la Porta di accesso del Comune ai domini applicativi del CNSD.

  Oltre ai flussi descritti in precedenza, nell'ambito dell'emissione CIE sono presenti anche i flussi di controllo e monitoraggio del sistema di emissione CIE. Tali flussi sono gestiti dagli Agenti di Controllo e dagli agenti di Monitoraggio, che devono essere correttamente installati e configurati nelle postazioni CIE (front office e back office). Tali agenti controllano e certificano lo stato di funzionamento ed operatività delle postazioni di front office, di back office e delle porte di accesso ai domini applicativi del CNSD. Al fine di ottenere l'autorizzazione all'emissione di CIE, il Comune è tenuto ad adottare le opportune politiche di sicurezza e le relative procedure operative per la configurazione della rete e per la gestione in sicurezza delle postazioni.

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocessi di emissione CIE – Schema logico flussi agenti di monitoraggio e controllo



Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di uso della CIE

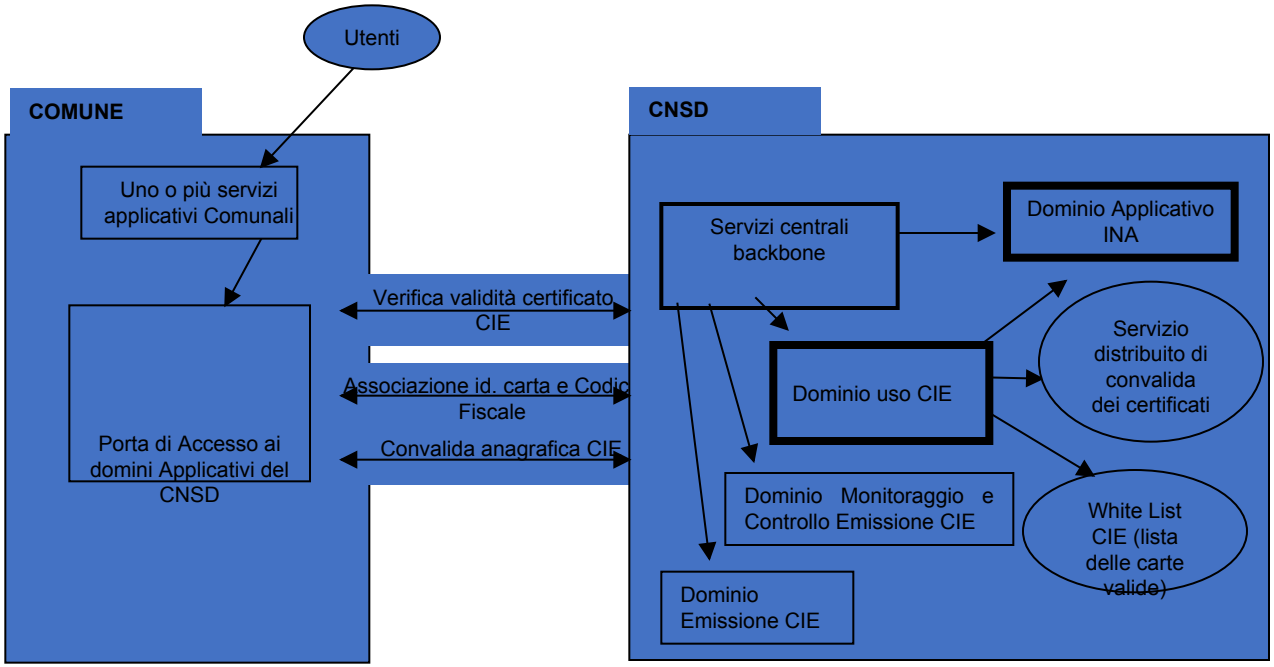
  Processi:

  - Abilitazione di una postazione di lavoro all’identificazione in rete della CIE
  - Abilitazione di un server comunale per l’identificazione in rete dei cittadini tramite CIE

Struttura e contenuti Piano di Sicurezza CIE

Ambito di riferimento Piano Sicurezza CIE

- Macroprocesso di uso della CIE – Schema logico

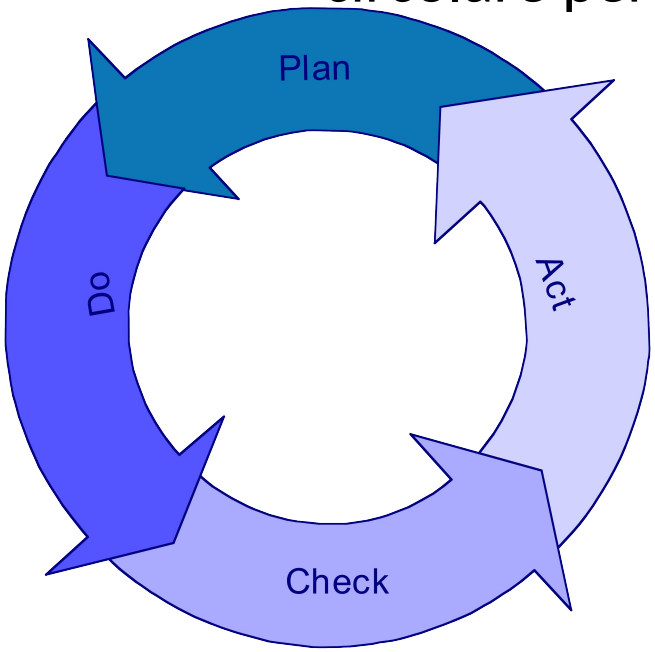


Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l'attuazione del Piano

- Metodologia utilizzata per l'attuazione del Piano di sicurezza

Metodologia PDCA metodologia che partendo da un'idea (**P**lan **D**o **C**heck **A**ct) di fondo, la sviluppa in modo circolare per verificarne i presupposti



Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l'attuazione del Piano

- Metodologia PDCA (**P**lan, **D**o, **C**heck, **A**ct):

  - **PLAN** Identificazione del problema, nella sua analisi, nell'individuazione delle cause reali, nonchè nella definizione e pianificazione delle azioni correttive.
  - **DO** Preparazione ed applicazione delle azioni pianificate.
  - **CHECK** Verifica dei i risultati raggiunti a fronte degli obiettivi attesi.
  - **ACT** Consolidamento dei risultati raggiunti, oppure nell'attivazione di un nuovo ciclo PDCA, con l'introduzione di opportuni correttivi, se non sono stati raggiunti i risultati attesi.

Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l’attuazione del Piano

- Applicazione delle 27001:
  - Definizione delle politiche generali di sicurezza;
  - Descrizione della struttura organizzativa di riferimento;
  - Analisi e gestione del rischio.

Struttura e contenuti Piano di Sicurezza CIE
Definizione delle politiche generali di sicurezza

- **1) Politica e standard di sicurezza (Security Policy)**
  - Il Comune deve attenersi ai seguenti principi generali:
  - Tutti gli accessi ai servizi applicativi del CNSD devono avvenire tramite la porta di accesso del Comune ai domini applicativi del CNSD;
  - Tutte le informazioni (dati, documenti, archivi, …) devono essere protette e mantenute;
  - Per la riservatezza dei contenuti scambiati, la sicurezza deve essere garantita anche a livello delle reti di comunicazioni dati;
  - Deve essere gestita la sicurezza sia di tutti gli apparati inerenti alla struttura comunale di emissione ed uso della CIE, sia del materiale di consumo considerato sensibile ai fini della sicurezza;
  - Tutte le registrazioni devono essere oggetto di monitoraggio costante (manuale o automatico);
  - Devono essere predisposte adeguate misure di sicurezza per l'accesso ai locali che ospitano le postazioni di front office, back office e la Porta di accesso al CNSD, nonché tutto il materiale impiegato nei processi di rilascio della CIE;
  - Ogni eventuale incidente o evento straordinario che possa pregiudicare la sicurezza deve essere oggetto di analisi e di rapporto scritto;
  - La Porta di accesso ai domini applicativi del CNSD e le postazioni di emissione CIE, sia di back office che di front office, devono essere utilizzati ai soli fini del rilascio ed uso della CIE e per l'accesso ai servizi del CNSD;
  - Tutti i progetti di nuove applicazioni/servizi devono essere inseriti nel piano per la sicurezza;

Struttura e contenuti Piano di Sicurezza CIE
Definizione delle politiche generali di sicurezza

- **1) Politica e standard di sicurezza (Security Policy)**
  - Tutte le modifiche, eventualmente apportate ai processi organizzativi interni al Comune, devono essere inserite nel Piano per la Sicurezza che va nuovamente trasmesso alla Prefettura per l'approvazione.
  - Per tutti i processi o macroprocessi CIE, deve essere individuato un responsabile di riferimento.
  - Nel caso in cui si dovessero utilizzare eventuali centri di allestimenti periferici per l'allestimento e la stampa delle CIE, devono essere gestiti in sicurezza tutti i possibili trasferimenti di CIE, di quantità di sicurezza e, in generale, di tutte le componenti e informazioni sensibili;
  - I servizi di monitoraggio degli accessi devono essere estesi a tutti gli apparati di front office e back office ed alla Porte di Accesso ai domini Applicativi del CNSD. In particolare si richiede:
    - Identificazione di ogni punto (back office, front office, Porta di accesso ai domini applicativi del CNSD) inerente all'uso e l'emissione della CIE;
    - certificazione delle operazioni, effettuata dagli agenti di monitoraggio e controllo installati sulle postazioni;
    - tracciatura delle operazioni effettuate con conseguente valutazione del livello di qualità dei servizi CIE, effettuata dagli agenti di monitoraggio e controllo installati sulle postazioni.

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **1) Politica e standard di sicurezza (Security Policy)**

  Relativamente alle problematiche di sicurezza inerenti all'emissione e l'uso della CIE, devono essere stabilite le seguenti responsabilità:

  - responsabilità di chi definisce, aggiorna ed approva le regole di sicurezza del Comune in ambito CIE;
  - responsabilità di chi fornisce le configurazioni e/o gli aggiornamenti che devono essere implementati nei sistemi di sicurezza (firewall, routing, switch, Porta di accesso ai domini applicativi del CNSD, postazioni di front office, postazioni di back office…) per assicurare il mantenimento dei livelli di sicurezza del Comune.
    - Deve essere inoltre individuato:
  - la persona fisica che effettua la gestione operativa dell'infrastruttura di sicurezza, sia relativamente agli applicativi software sia relativamente ai sistemi di calcolo su cui i medesimi sono installati;
  - la persona fisica chi effettua la gestione di tutti gli altri sistemi presenti nel Comune e comunque attinenti all'emissione ed all'uso della CIE;
  - la persona fisica effettua la manutenzione di tutti gli apparati attinenti all'emissione ed all'uso della CIE presenti presso il Comune.

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **2) Organizzazione per la sicurezza (Security Organization)**
  - Il Comune deve definire e costituire un settore preposto a sovrintendere e controllare i processi e le attività legate alla sicurezza dell’infrastruttura di emissione ed utilizzo della CIE.

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **3) Classificazione e Controllo delle risorse (Asset Classification and Control)**
  - **Il Comune deve raccogliere e classificare informazioni sulle risorse. In particolare le risorse da considerare sono:**
    - **Sistemi informativi;**
    - **Sistemi di rete tra le varie sedi (intranet, internet);**
    - **Postazioni di lavoro;**
    - **Postazioni di Front Office;**
    - **Postazioni di Back Office;**
    - **Porta di accesso ai domini applicativi del CNSD;**
    - **Punti di accesso multimediali aperti al pubblico.**
  - **Gestione Inventario delle risorse**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **4) Sicurezza del personale (Personnel Security)**
  - **Ridurre il rischio di errori umani, furto, frode o uso improprio delle strutture comunali;**
  - **Accertarsi che il personale addetto sia stato informato sui possibili rischi relativi alla sicurezza delle informazioni.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **5) Sicurezza materiale e ambientale (Physical and Environmental Security)**
  - **Impedire l'accesso non autorizzato, il danneggiamento e l'interferenza all'interno del flusso delle informazioni;**
  - **Impedire la perdita o il danneggiamento dei dati necessari alla corretta esecuzione dei processi di emissione ed uso della CIE;**
  - **Impedire l'interruzione delle attività.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **6) Gestione dei sistemi e delle reti (Computer and Network Management)**
  - **assicurare il corretto e sicuro funzionamento sistemi di elaborazione e delle reti;**
  - **minimizzare il rischio di guasti dei sistemi;**
  - **proteggere l'integrità del software di base e delle informazioni;**
  - **assicurare la disponibilità dei processi di elaborazione dell'informazione e di comunicazione;**
  - **garantire la salvaguardia delle informazioni in rete e la protezione delle infrastrutture di rete;**
  - **evitare la perdita, modifica o uso improprio delle informazioni scambiate in rete.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **6) Gestione dei sistemi e delle reti (Computer and Network Management)**
  - **Tutti gli accessi ai servizi INA ed ai servizi di emissione ed uso della CIE, devono avvenire nell'ambito delle seguenti infrastrutture di sicurezza:**
    - **Backbone di Sicurezza del CNSD e Porta di accesso ai domini applicativi del CNSD;**
    - **Sistema di Sicurezza del Circuito di Emissione delle carte di identità e dei documenti di identità elettronica**

Porta di accesso ai domini applicativi del CNSD:

- **Rappresenta il punto di presa in carico delle comunicazioni provenienti dal Comune e del loro successivo inoltro al CNSD.**
- **Certifica il punto di origine delle comunicazioni, individuando univocamente il Comune che comunica con il CNSD**
- **Tutte le comunicazioni devono avvenire esclusivamente tramite la porta di accesso.**
- **Ciascun Comune deve registrare presso il Ministero dell'Interno la porta di accesso ai domini applicativi del CNSD.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **6) Gestione dei sistemi e delle reti (Computer and Network Management)**
  - **In conformità con le infrastrutture di sicurezza descritte:**
    - **identificazione delle postazioni di lavoro che si collegano ai servizi INA e ai servizi di emissione della CIE;**
    - **sistema di documentazione, monitoraggio ed allarmi dei servizi, che fornisca in modo preciso ed inequivocabile tutte le informazioni necessarie a descrivere le anomalie di sicurezza e ad individuare le responsabilità (svolta dagli agenti di monitoraggio e controllo installati sulle postazioni);**
    - **sistema di allarme inerente agli accessi ed usi impropri dei servizi.**

  - **Gli accessi in rete ai servizi del CNSD devono avvenire nel pieno rispetto delle "*Regole tecniche e di sicurezza per l'accesso ai domini applicativi del CNSD*".**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **7) Controllo degli accessi (System Access Control)**
  - **Controllare l'accesso alle informazioni;**
  - **Prevenire l'accesso non autorizzato alle informazioni;**
  - **Assicurare la protezione dei servizi in rete;**
  - **Prevenire l'accesso non autorizzato alle postazioni di emissione sia di front office che di back office ed alla Porta di accesso ai domini applicativi del CNSD;**
  - **Rilevare attività non autorizzate;**
  - **Garantire la sicurezza delle informazioni quando sono utilizzate da eventuali postazioni mobili in rete;**
  - **Garantire un adeguato controllo degli accessi ai locali comunali che ospitano le postazioni di front office, di back office, la Porta di accesso al CNSD, nonché tutto il materiale impiegato nei processi di rilascio della CIE.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **8) Sviluppo e manutenzione dei sistemi (System Development and Maintenance)**
  - **Garantire che le regole di sicurezza siano realmente attuate nei sistemi informatici in esercizio;**
  - **Assicurare che la conduzione dei progetti informatici e le relative attività di supporto siano eseguite secondo le regole qui riportate;**
  - **Tutti i progetti di nuove applicazioni/servizi devono essere inseriti nel Piano per la Sicurezza.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **9) Gestione della continuità del servizio (Business Continuity Management)**
  - **contrastare le interruzioni delle attività di servizio e dei processi di servizio critici, causati da malfunzionamenti o da eventuali avvenimenti straordinari.**
  - **garantire la continuità dei processi in funzione del loro valore e della qualità dei prodotti/servizi erogati,**
  - **prevenire e minimizzare l'impatto di incidenti intenzionali o accidentali e dei conseguenti possibili danni**
  - **Per una corretta gestione del governo delle informazioni i sistemi devono garantire la continuità dei servizi.**

  - **Per la Gestione della continuità del servizio è richiesto:**
    - **Classificazione degli eventi straordinari:**
    - **Classificazione dei sistemi**
    - **Definizione piano di emergenza**

Struttura e contenuti Piano di Sicurezza CIE
Definizione delle politiche generali di sicurezza

- **9) Gestione della continuità del servizio (Business Continuity Management)**
  - **Classificazione degli eventi straordinari:**
    - **Disastro di primo livello** su un ufficio può causare, in alcuni casi, la parziale ma non completa distruzione delle operazioni svolte giornalmente. La situazione può essere risolta usando personale dell'ufficio stesso ed effettuando localmente attività di ripristino.
    - **Disastro di secondo livello** può coinvolgere diversi uffici. Le operazioni di routine possono essere distrutte ed i processi critici dovranno essere eseguiti in altri uffici. Il personale dell'ufficio potrebbe avvalersi dell'assistenza di soggetti esterni. Il coordinamento delle persone avviene attraverso un centro di operazioni di emergenza appositamente costituito dal Comune.
    - **Disastro di terzo livello** può coprire una vastissima zona, ad esempio una regione; tipici esempi di questi eventi straordinari sono: inondazioni, terremoti o uragani. In questo caso sono richieste risorse esterne ed assistenza, ma il ripristino completo può richiedere settimane o mesi. Generalmente un disastro di questo livello comporta il blocco dell'operatività dei sistemi.

Struttura e contenuti Piano di Sicurezza CIE
Definizione delle politiche generali di sicurezza

- **9) Gestione della continuità del servizio (Business Continuity Management)**

  - **Classificazione dei sistemi**
    - **Critici** Le relative funzioni non possono essere eseguite senza essere sostituite da strumenti (mezzi) di caratteristiche identiche. Le applicazioni critiche non possono essere sostituite con metodi manuali. La tolleranza in caso di interruzione è molto bassa, di conseguenza il costo di una interruzione è molto alto.
    - **Vitali** Le relative funzioni possono essere svolte manualmente, ma solo per un breve periodo di tempo. Vi è una maggiore tolleranza all'interruzione rispetto a quella prevista per i sistemi critici; conseguentemente il costo di un'interruzione è inferiore, anche perché queste funzioni possono essere riattivate entro un breve intervallo di tempo (generalmente entro cinque giorni).
    - **Delicati** Queste funzioni possono essere svolte manualmente, a costi tollerabili, per un lungo periodo di tempo. Benché queste funzioni possano essere eseguite manualmente, il loro svolgimento risulta comunque difficoltoso e richiede l'impiego di un numero di persone superiore a quello normalmente previsto in condizioni normali.
    - **Non-critici** Le relative funzioni possono rimanere interrotte per un lungo periodo di tempo, con un costo modesto, o nullo, e si richiede un limitato sforzo di riattivazione quando il sistema viene ripristinato.

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **9) Gestione della continuità del servizio (Business Continuity Management)**
  - **Definizione piano di emergenza:**
    - **I sistemi classificati e documentati come critici, devono essere ripristinati prioritariamente;**
    - **il piano d'emergenza deve prevedere il ripristino di tutte le funzioni e non solo i servizi informatici centrali;**
    - **Per assicurare la continuità dei servizi devono essere valutate le strategie di ripristino più opportune quali:**
      - **siti alternativi;**
      - **metodi di back up;**
      - **sostituzione dei sistemi hardware di elaborazione;**
      - **ruoli e responsabilità dei gruppi tecnici di lavoro.**

Struttura e contenuti Piano di Sicurezza CIE

Definizione delle politiche generali di sicurezza

- **10) Conformità (Compliance)**
  - **garantire il rispetto delle leggi civili, penali, obblighi statutari, regolamentari o contrattuali e di qualsiasi requisito di sicurezza;**
  - **garantire il rispetto di tutte le direttive del Ministero dell'Interno;**
  - **assicurare la conformità dei sistemi con i criteri e gli standard di sicurezza nazionali ed internazionali.**

Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l’attuazione del Piano

- Applicazione delle 27001:
  - Definizione delle politiche generali di sicurezza;
  - Descrizione della struttura organizzativa di riferimento;
  - Analisi e gestione del rischio.

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Descrizione della struttura organizzativa:**
  - Presentazione del Comune
  - Descrizione degli uffici e dei servizi
  - Ruoli e figure professionali previste
  - Descrizione dei dispositivi installati
  - Altre informazioni sensibili per la sicurezza
    - Ubicazione dei servizi e degli uffici negli immobili
    - Descrizione dell’infrastruttura di sicurezza per ciascun immobile
    - Elenco del personale e sua assegnazione agli uffici

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Presentazione del Comune**
  - ***Denominazione Comune***
  - ***Provincia***
  - ***Codice ISTAT***
  - ***Sede principale comunale***
  - ***Telefono***
  - ***Fax***
  - ***Estensione territoriale***
  - ***Popolazione residente***
  - ***Popolazione residente ultra 15enni***

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Descrizione degli uffici e dei servizi**
  - **Settore/area:** il Comune è diviso in più settori/aree. Ogni settore/area identifica una macro area con un proprio responsabile di riferimento.
  - **Servizi:** nell'ambito di un settore/area sono erogati più servizi. Per ogni servizio è previsto un responsabile di riferimento.
  - **Uffici:** un servizio, a sua volta, può essere diviso in più uffici addetti a mansioni differenti o, comunque, alla copertura di diverse aree territoriali del Comune (per esempio circoscrizioni). Per i comuni medio/piccoli è possibile che l'ufficio corrisponda al servizio stesso. In tal caso riportare sotto la voce dell'ufficio la stessa voce del servizio.
  - **Adempimenti** **breve descrizione del ruolo dell'ufficio**
  - **Infrastruttura logistica** **descrizione sintetica dell'infrastruttura logistica dell'ufficio**

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Ruoli e figure professionali previste**
  - ***Ufficio***
  - ***Ruolo***
  - ***Descrizione ruolo*:**
  - ***Figura professionale***
  - ***Responsabilità***

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Ruoli e figure professionali previste – Responsabili obbligatori**
  - Responsabile comunale per la sicurezza degli accessi al CNSD
  - Responsabile della sicurezza CIE
  - Responsabile della custodia delle Quantità di Sicurezza (certificati per emissione CIE)
  - Responsabile caricamento INA
  - Responsabile di emissione della CIE
  - Responsabile della sicurezza dei dati (backup,…)
  - Responsabile delle postazioni di emissione sia di front office che di back office
  - Responsabile della Porta di accesso ai domini applicativi del CNSD
  - Responsabile della rete
  - Responsabile dei servizi tecnici
  - Responsabile delle verifiche e delle ispezioni (auditing)
  - Responsabile della manutenzione

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Descrizione dei dispositivi installati**
  - ***Tipologia*: tipologia del dispositivo (postazione emissione, Porta di accesso al CNSD, postazione di lavoro, dispositivi di rete,…)**
  - ***Dispositivo* descrizione del dispositivo (per esempio per un dispositivo di rete evidenziare se trattasi di firewall, switch, proxy o altro)**
  - ***Quantità* numero di dispositivi presenti**
  - ***Caratteristiche tecniche* breve descrizione delle principali caratteristiche tecniche del dispositivo**
  - ***Configurazione* breve descrizione della configurazione dei dispositivi in riferimento alle politiche di sicurezza (accessi logici, collegamento su rete, condivisione risorse …)**
  - ***Assegnazione* ufficio, servizio o settore è assegnato il dispositivo installato**
  - ***Responsabile* responsabile della risorsa**
  - ***Autorizzazioni* elenco delle figure professionali abilitate ad accedere e descrizione del tipo di accesso**

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- **Ubicazione dei servizi e degli uffici**
  - ***Ufficio*** **Descrizione ufficio**
  - ***Identificativo ufficio*** **Nel caso in cui un ufficio sia dislocato in più ambienti, è necessario assegnare un identificativo per ogni ambiente (ad esempio la numerazione della stanza)**
  - ***Immobile*** **denominazione dell'immobile (Palazzo Comunale, Circoscrizione, Municipio, …)**
  - ***Ubicazione immobile*** **indirizzo completo dell'immobile**
  - ***Ubicazione dell'ufficio rispetto all'immobile*** **descrizione dell'ubicazione dell'ufficio all'interno dell'immobile (per esempio piano terzo, stanza n. 4)**

Struttura e contenuti Piano di Sicurezza CIE

Descrizione della struttura organizzativa

- Descrizione dell'infrastruttura di sicurezza per ciascun immobile
  - ***Immobile*** ***denominazione dell'immobile***
  - ***Ubicazione*** ***indirizzo completo relativo all'immobile***
  - ***Tipologia immobile:*** ***tipologia dell' immobile (per esempio appartamento, palazzo o altro ancora)***
  - ***Tipologia infrastruttura di sicurezza*** ***- fisica e ambientali (per esempio inferriate di protezione per le finestre, porte blindate, ...)***
    - organizzativa (sorveglianza, accesso ai locali, rapporti con altre istituzioni, ...)
    - tecnologica (sistemi di allarme, sistemi di rilevazione incendi, ...)
  - ***Sistema di sicurezza*** ***caratteristiche strutturali del sistema di sicurezza (per esempio inferriate, sistema di allarme, sistema di sorveglianza ...)***
  - ***Descrizione*** ***descrizione sintetica delle caratteristiche tecniche del sistema di sicurezza***

Struttura e contenuti Piano di Sicurezza CIE
Descrizione della struttura organizzativa

- Elenco del personale e sua assegnazione agli uffici
  - Personale Comunale
    - Ufficio
    - Ruolo
    - Nominativo del personale
    - Personale temporaneamente incaricato
  - Fornitore esterno di servizi
    - Denominazione fornitore
    - Descrizione
    - Sede
    - Nominativo del responsabile di riferimento

Struttura e contenuti Piano di Sicurezza CIE

Metodologia utilizzata per l’attuazione del Piano

- Applicazione delle 27001:
  - Definizione delle politiche generali di sicurezza;
  - Descrizione della struttura organizzativa di riferimento;
  - Analisi e gestione del rischio.

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio

- **Analisi e gestione del rischio:**
  - **Individuazione “asset” di interesse per la sicurezza**
  - **Classificazione minacce e vulnerabilità**
  - **Valutazione del rischio**
  - **Trattamento del rischio**
  - **Attuazione trattamenti**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio - Individuazione asset

- **Individuazione “asset” di interesse per la sicurezza**
  - **Definizione “asset”** Qualunque tipo di risorsa elementare utile alla realizzazione di un processo
  - **Passi richiesti per l’individuazione degli asset**
    - **Classificazione asset di interesse**
    - **Definizione singoli processi elementari che compongono i macroprocessi legati all’emissione ed all’uso della CIE**
    - **Individuazione degli asset di interesse nell’ambito dei processi elementari**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio - Individuazione asset

- **Classificazione asset di interesse per la sicurezza**
  - Informazioni
  - Reti
  - Infrastrutture
  - Hardware
  - Software
  - Risorse umane

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio - Individuazione asset

- **Definizione singoli processi elementari inerenti l'emissione e l'uso della CIE**
  - Definizione Macroprocessi:
    - Macroprocesso di caricamento INA
    - Macroprocesso di emissione CIE
    - Macroprocesso di uso della CIE
  - Definizione processi
  - Definizione delle singole attività

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Individuazione Asset

- **Individuazione degli asset di interesse nell’ambito dei processi elementari**
  - Individuazione degli asset di interesse per ogni singola attività
  - Definizione dei controlli considerati obbligatori ai fini della sicurezza

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Individuazione asset

- **Esempio individuazione asset**
  - **Macroprocesso caricamento INA**
  - **Processo "Allineamento dei codici fiscali con gli archivi dell'Anagrafe Tributaria"**
  - **Attività: "Il Comune estrae dalla propria anagrafe le corrispondenze tra dati anagrafici e codici fiscali, ivi compresi i dati anagrafici ai quali non è associato un codice fiscale: processo elementare di elaborazione"**

CONTROLLI:

Deve essere prestata particolare attenzione alla:

- **gestione delle copie di sicurezza dell'anagrafe locale**
- **estrazione dei dati anagrafici,**
- **gestione del dispositivo fisico di memorizzazione dell'archivio delle corrispondenze,**
- **sicurezza delle reti coinvolte.**
- **continuità del servizio in caso di incidenti e eventi straordinari**
- **gestione degli accessi alle risorse**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Individuazione asset

- **Esempio individuazione asset**
  - **Macroprocesso caricamento INA**
  - **Processo "Allineamento dei codici fiscali con gli archivi dell'Anagrafe Tributaria"**
  - **Attività: "Il Comune estrae dalla propria anagrafe le corrispondenze tra dati anagrafici e codici fiscali, ivi compresi i dati anagrafici ai quali non è associato un codice fiscale: processo elementare di elaborazione"**

Asset individuati:

- **Informazioni**
  - Archivio anagrafico del Comune;
  - Archivio delle corrispondenze dato anagrafico ✎ codice fiscale: output del processo.
  - Archivio delle abilitazioni per l'uso dei sistemi comunali: input del processo.
- **Reti**
  - Le reti dati del Comune sulle quali transitano gli asset informativi individuati
- **Infrastrutture**
  - La/e sede/i comunale/i dell'archivio anagrafico comunale.
  - La/e sede/i comunale/i presso cui l'archivio delle corrispondenze viene depositato.
  - Le strutture operative eventualmente incaricate del trasporto dei supporti fisici su cui sono archiviate le corrispondenze.

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Individuazione asset

- **Esempio individuazione asset**
  - **Macroprocesso caricamento INA**
  - **Processo "Allineamento dei codici fiscali con gli archivi dell'Anagrafe Tributaria"**
  - **Attività: "Il Comune estrae dalla propria anagrafe le corrispondenze tra dati anagrafici e codici fiscali, ivi compresi i dati anagrafici ai quali non è associato un codice fiscale: processo elementare di elaborazione"**

Asset individuati:

- **Hardware**
  - Il/i sistema/i comunale/i di gestione ed archiviazione dei dati anagrafici.
  - Il/i terminale/i da cui si accede all'anagrafe per attivare la procedura di estrazione dell'archivio delle corrispondenze.
  - I dispositivi di memorizzazione dell'archivio delle corrispondenze.
  - La porta di accesso ai domini applicativi del CNSD
- **Software**
  - Il Sistema Informativo Comunale
  - I servizi di estrazione dei dati anagrafici dall'archivio anagrafico comunale.
  - Il software d'estrazione delle corrispondenze.
  - Il Software di memorizzazione dell'archivio delle corrispondenze sui dispositivi hardware preposti.
- **Risorse umane**
  - Il responsabile dell'anagrafe
  - Il responsabile del Sistema Informativo Comunale
  - I tecnici informatici incaricati dell'attuazione del processo di estrazione e creazione dell'archivio delle corrispondenze.
  - L'incaricato del deposito dell'archivio delle corrispondenze

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio

- **Analisi e gestione del rischio:**
  - **Individuazione “asset” di interesse per la sicurezza**
  - **Classificazione minacce e vulnerabilità**
  - **Valutazione del rischio**
  - **Trattamento del rischio**
  - **Attuazione trattamenti**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Minacce e vulnerabilità

- **Classificazione minacce e vulnerabilità**
  - **Definizione minaccia** causa potenziale di un evento non desiderato che può avere come conseguenza danni al Comune ed ai suoi asset, ovvero ai singoli processi elementari che compongono i macroprocessi legati all'emissione ed all'uso della CIE.

  - **L'attuarsi di una minaccia, può consistere in:**
    - **distruzione di un asset**
    - **corruzione o modifica di un asset**
    - **sottrazione o perdita di un asset**
    - **pubblicazione di informazioni riservate**
    - **uso non lecito di un asset**
    - **interruzione del servizio**

  - **Gli eventi inerenti alle minaccia possono essere:**
    - **Ambientali**
    - **Intenzionali**
    - **Accidentali**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Minacce e vulnerabilità

- **Classificazione minacce e vulnerabilità**
  - **Minacce ambientali**
    - **Contaminazione**
    - **Terremoto**
    - **Interferenze Elettroniche**
    - **Valori estremi di temperatura e umidità**
    - **Blackout**
    - **Incendio**
    - **Esondazione/Inondazione**
    - **Fluttuazioni dell'alimentazione elettrica**
    - **Tempesta**
    - **Cambiamenti della marea**
    - **Parassiti**

Struttura e contenuti Piano di Sicurezza CIE
Analisi e gestione del rischio – Minacce e vulnerabilità

- **Classificazione minacce e vulnerabilità**
  - **Minacce intenzionali**
    - **Denial of Service (attacchi informatici che causano la disconnessione dal server o il possibile blocco del computer)**
    - **Appropriazione indebita di informazioni protette**
    - **Incendio**
    - **Attività industriali**
    - **Codice dannoso (virus, …)**
    - **Distruzione intenzionale dei dati e delle strutture**
    - **IP Masquerading (attacco informatico che comporta la falsificazione degli indirizzi IP con conseguente falsificazione del mittente reale della comunicazione)**
    - **Ripudio delle comunicazioni o transazioni compiute**
    - **Sabotaggio**
    - **Induzione fraudolenta a rivelare o diffondere dati sensibili (in particolar modo su Internet)**
    - **Furto e frode**
    - **Accesso non autorizzato ai dati**
    - **Accesso non autorizzato a un server di posta**
    - **Cambiamenti di software non autorizzati**
    - **Uso di “software pirata” (software privo di relativa licenza e scaricato, per esempio, da internet con i relativi aggiornamenti)**
    - **Intrusione di “hacker” in siti web (attacchi informatici effettuati verso i siti web con relativa alterazione degli stessi)**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Minacce e vulnerabilità

- **Classificazione minacce e vulnerabilità**
  - **Minacce accidentali**
    - **Incendio dell'edificio**
    - **Guasto degli apparati di comunicazione**
    - **Errori imputabili a terzi, in servizi gestiti in outsourcing (ovvero gestiti da personale esterno all'amministrazione comunale)**
    - **Assenza di personale "chiave" ovvero di personale indispensabile per la corretta erogazione dei servizi**
    - **Invio dei messaggi su canali di comunicazione non adatti o errati (esempio: invio di fax al numero sbagliato)**
    - **Errori del Personale Operativo**
    - **Errori imputabili al software**
    - **Guasti tecnici**
    - **Errori delle linee di trasmissione dati**

Struttura e contenuti Piano di Sicurezza CIE
Analisi e gestione del rischio – Minacce e vulnerabilità

- **Classificazione minacce e vulnerabilità**
  - **Definizione vulnerabilità** insieme di condizioni, punti deboli degli asset, che possono agevolare l'attuarsi di una o più minacce
  - **Tipicamente una vulnerabilità è conseguenza di:**
    - **un'errata procedura (informatica e/o organizzativa),**
    - **personale non sufficientemente addestrato,**
    - **tecnologie non correttamente configurate,**
    - **tecnologie difettose.**
  - **La rilevazione delle vulnerabilità rispetto alle minacce consente:**
    - **la misurazione del livello di pericolosità di una minaccia rispetto al sistema comunale;**
    - **la classificazione esaustiva delle minacce da considerare nel piano**
    - **l'analisi e la rilevazione di nuove vulnerabilità e, conseguentemente, delle potenziali minacce ad esse associate**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Minacce e vulnerabilità

- **Esempio vulnerabilità**

Tipo Minaccia	Minaccia intenzionale
Minaccia	Accesso non autorizzato ai dati

- **Elenco vulnerabilità:**
  - **Assenza di aggiornamento periodico delle password**
  - **Mancanza di sistemi che rilevino, in tempo reale, eventi su rete non autorizzati**
  - **Non adeguato controllo degli accessi alle postazioni di lavoro e/o agli uffici**
  - **Password troppo semplici**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio

- **Analisi e gestione del rischio:**
  - **Individuazione “asset” di interesse per la sicurezza**
  - **Classificazione minacce e vulnerabilità**
  - **Valutazione del rischio**
  - **Trattamento del rischio**
  - **Attuazione trattamenti**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Valutazione rischio

- **Valutazione del rischio**

La valutazione del rischio è effettuata in base a:

- **incidenza delle minacce sulle singole attività dei processi e macroprocessi di emissione ed uso della CIE**
  - **Associazione minacce e vulnerabilità agli asset di interesse**

- **potenziale incidenza delle minacce sulla sicurezza dell'informazione/asset:**
  - **Riservatezza**
  - **Integrità**
  - **Disponibilità**
  - **Responsabilità**
  - **Autenticità**
  - **Affidabilità**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Valutazione rischio

- **Esempio associazione minacce e vulnerabilità agli asset di interesse**

MACROPROCESSO		PROCESSO		ATTIVITÀ
Caricamento dell'INA		Allineamento dei codici fiscali con gli archivi dell'Anagrafe Tributaria		1) Il Comune estrae dalla propria anagrafe le corrispondenze tra dati anagrafici e codici fiscali, ivi compresi i dati anagrafici ai quali non è associato un codice fiscale: processo elementare di elaborazione
ID	Classi	Asset	Minacce	Vulnerabilità
1	Informazioni	Archivio anagrafico del Comune	1,13,16,17,20,22,23,27,32	Mancanza di sistemi che rilevino, in tempo reale, eventi su rete
2	Informazioni	Archivio delle corrispondenze dato anagrafico-codice fiscale	1,13,16,17,20,22,23,27,32	Mancanza di sistemi che rilevino, in tempo reale, eventi su rete prima pagina del documento da inviare, coincida con il numero telefonico digitato)
3	Informazioni	Archivio delle abilitazioni per l'uso dei sistemi comunali	1,13,16,17,20,22,23,27,32	Mancanza di sistemi che rilevino, in tempo reale, eventi su rete l'organizzazione ad accessi non autorizzati Assenza di specifiche procedure di controllo (prima di inviare un fax, verificare che il numero telefonico del fax riportato sulla prima pagina del documento da inviare, coincida con il numero telefonico digitato)
4	Reti	Le reti dati del Comune sulle quali transitano gli asset informativi individuati	3,29,30,35,36	Nei contratti con i fornitori dei dispositivi hardware "critici" è previsto un tempo di ripristino troppo lungo (più di quattro ore) Non è stata prevista la duplicazione dei dispositivi hardware "
5	Infrastrutture	La/e sede/i comunale/i dell'archivio anagrafico comunale	2,5,6,7,14,17,20,28	Le sedi comunali non sono dotate di allarmi anti-incendio Mancanza di dispositivi per la rilevazione di incendi

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Valutazione rischio

- **Valutazione potenziale incidenza delle minacce sulla sicurezza dell'informazione/asset:**

  - Per ogni attività è necessario valutare l'incidenza delle minacce di riferimento sugli aspetti relativi alla sicurezza dell'informazione (riservatezza, integrità, disponibilità, responsabilità, autenticità ed affidabilità delle informazioni). I valori utilizzati sono:
    - **N**ULLO **= 0**
    - **B**ASSO **= 1**
    - **M**EDIO **= 3**
    - **A**LTO **= 7**
    - **C**RITICO **= 15**

  - La valutazione complessiva di una minaccia nell'ambito di un'attività è data dalla media delle valutazioni dei singoli aspetti della sicurezza (punto precedente) arrotondata al valore immediatamente più alto. Segue la regola di valutazione del risultato:
    - 0 Ⓟ N-NULLO
    - 1 Ⓟ B-BASSO
    - 2|3|4 Ⓟ M-MEDIO
    - 5|6|7|8|9 Ⓟ A-ALTO
    - 10|11|12|13|14|15 Ⓟ C-CRITICO

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Valutazione rischio

- **Esempio valutazione rischio**

MACROPROCESSO	PROCESSO	ATTIVITÀ
Caricamento dell'INA	Allineamento dei codici fiscali con gli archivi dell'Anagrafe Tributaria	1) Il Comune estrae dalla propria anagrafe le corrispondenze tra dati anagrafici e codici fiscali, ivi compresi i dati anagrafici ai quali non è associato un codice fiscale: processo elementare di elaborazione

Minaccia	Impatto						Rischio		
	R	I	D	Re	Au	Af	Valore (NBMAC)	Provoca interruzione del servizio? (Sì/No)	Commento
6 - Incendio			A				M	SI	
13 - Appropriazione indebita di informazioni protette	A						M	NO	
14 - Incendio			B				B	SI	
16 - Codice dannoso (virus, …)	B	C	C				A	SI	
17 - Distruzione intenzionale dei dati e delle strutture		B					B	SI	
20 - Sabotaggio		B	B				B	SI	
22 - Furto e frode	A		N	B	B		M	NO	
23 - Accesso non autorizzato ai dati	A	B		B	B	B	M	NO	
25 - Cambiamenti di software non autorizzati	N	M	A	M		A	M	SI	
27 - Intrusione di "hacker" in siti web (attacchi informatici effettuati verso i siti web con relativa alterazione degli stessi)	A	A	M		B		M	SI	
28 - Incendio dell'edificio			M				B	SI	
29 - Guasto degli apparati di comunicazione			A				M	SI	

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio

- **Analisi e gestione del rischio:**
  - **Individuazione “asset” di interesse per la sicurezza**
  - **Classificazione minacce e vulnerabilità**
  - **Valutazione del rischio**
  - **Trattamento del rischio**
  - **Attuazione trattamenti**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Trattamento rischio

- **Trattamento rischio**
  - **Nel piano di sicurezza “alfa”, si considerano le sole minacce alle quali corrisponda uno dei seguenti valori di rischio:**
    - **CRITICO**
    - **ALTO**
    - **MEDIO**
  - **Le minacce il cui valore di rischio è corrispondente a “BASSO”, devono comunque essere tenute sotto controllo**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Trattamento rischio

- **La definizione del trattamento rischio prevede:**
  - **Minaccia**
  - **Trattamento scelto: azioni che si intendono intraprendere per attenuare/risolvere prevenire e/o tenere sotto controllo la minaccia. Il trattamento scelto può fare riferimento a una o più <u>procedure operative</u>**
  - **Nel caso in cui si preveda di aggiornare il trattamento:**
    - **Politiche di sicurezza di riferimento**
    - **Responsabile**
    - **Risorse**
    - **Tempi: stima dei tempi (giorni solari) pianificati per l'attuazione del trattamento scelto.**
  - **È garantita la continuità del servizio? (Sì/No): indica se il trattamento sia idoneo ad evitare l'interruzione del servizio**
  - **Controlli: tipologia dei controlli che viene assicurata dal trattamento**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Trattamento rischio

- **Procedura operativa**
  - **Che cos'è una procedura operativa?**

    Insieme di regole che normano la modalità di gestione di un processo considerato sensibile per la sicurezza

  - **Una o più procedure operative possono costituire il trattamento scelto per il rischio di una minaccia**
  - **Una procedura operativa può essere di riferimento per il trattamento del rischio di più minacce**

Struttura e contenuti Piano di Sicurezza CIE
Analisi e gestione del rischio – Trattamento rischio

- **Procedure operative obbligatorie**
  - Procedura di controllo degli accessi.
  - Procedura di gestione degli account.
  - Procedura di registrazione dei sistemi comunali presso la Porta di Accesso ai domini applicativi del CNSD.
  - Procedura di gestione del materiale in entrata ed in uscita
  - Procedura di gestione delle Quantità di Sicurezza.
  - Procedura di gestione delle CIE inizializzate
  - Procedura di Manutenzione degli apparati:
  - Procedura di Gestione della rete
  - Procedura di Gestione della Porta di accesso ai domini applicativi del CNSD:
  - Procedura di Gestione delle Postazioni di Emissione:
  - Procedura di emissione CIE:
  - Procedura di caricamento dell’INA
  - Procedure di attuazione delle norme vigenti inerenti la sicurezza dell’edificio e del personale
  - Procedure operative per la gestione di eventi straordinari

Struttura e contenuti Piano di Sicurezza CIE
Analisi e gestione del rischio – Trattamento rischio

- **Procedure operative**

Informazioni richieste per la definizione di una procedura operativa:

- **Descrizione sintetica**
- **Descrizione dei Macroprocessi CIE di riferimento**
- **Descrizione delle politiche di sicurezza di riferimento**
- **Descrizione dei ruoli richiesti e delle relative competenze/responsabilità**
- **Elenco delle risorse:**
  - **Tipologia della risorsa (tecnologica, logistica, informativa)**
  - **Descrizione della risorsa (postazione di lavoro, elenco autorizzazioni,…)**
  - **Funzione svolta dalla risorsa all'interno della procedura**
  - **Responsabile di riferimento**
  - **Modalità di gestione degli accessi**
  - **Controlli previsti**
- **Descrizione del flusso della procedura: descrivere il flusso di lavoro della procedura, indicando i momenti di interazione tra le diverse figure professionali coinvolte.**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio

- **Analisi e gestione del rischio:**
  - **Individuazione “asset” di interesse per la sicurezza**
  - **Classificazione minacce e vulnerabilità**
  - **Valutazione del rischio**
  - **Trattamento del rischio**
  - **Attuazione trattamenti**

Struttura e contenuti Piano di Sicurezza CIE

Analisi e gestione del rischio – Attuazione trattamenti

- **Attuazione trattamenti**
  - La fase DO della metodologia adottata prevede la trasformazione delle tabelle di trattamento del rischio nel diagramma GANTT del piano di sicurezza Comunale.
  - Rispetto alla definizione del trattamento del rischio è necessario indicare le date di inizio e termine delle attività

Struttura e contenuti Piano di Sicurezza CIE

Monitoraggio del Piano di Sicurezza

- **Monitoraggio del Piano di Sicurezza**
  - **La fase di CHECK (monitoraggio e validazione) della metodologia prevede venga verificata, la corretta attuazione del piano.**
  - **Attività previste:**
    - **Controllo dello stato di attuazione del piano**
    - **Monitoraggio di tutti gli eventi di interesse per la sicurezza comunale CIE**

Struttura e contenuti Piano di Sicurezza CIE

Monitoraggio del Piano di Sicurezza

- **Controllo dello stato di attuazione del piano:**
  - **Verifica avvenuta nomina dei responsabili considerati “obbligatori”**
  - **Verifica stato di attuazione delle procedure operative**
  - **Verifica stato di attuazione dei trattamenti del rischio**

Struttura e contenuti Piano di Sicurezza CIE

Monitoraggio del Piano di Sicurezza

- **Monitoraggio di tutti gli eventi di interesse per la sicurezza comunale CIE**

  Per ogni evento deve essere indicato:

  - Se l’evento è inerente un processo/attività presente o meno nel piano di sicurezza
  - Descrizione del l’evento
  - Descrizione della minaccia e della vulnerabilità che lo ha reso possibile ed indicazione se lo stesso è trattato nel piano di sicurezza
  - Procedura operativa e/o controllo di riferimento per l’evento rilevato
  - Descrizione degli interventi effettuati
  - Descrizione dell’esito degli interventi
  - Indicazione se è stata provocata interruzione di servizi

Struttura e contenuti Piano di Sicurezza CIE

Manutenzione ed evoluzione del Piano di Sicurezza

- **Manutenzione ed evoluzione del Piano di Sicurezza**
  - La fase di ACT della metodologia prevede il consolidamento dei risultati e/o l’introduzione di opportuni adeguamenti correttivi prevedendo, qualora richiesto, l’attivazione di un nuovo ciclo PDCA (Plan, Do, Check, Act)
  - Obiettivi: ottenere il nuovo piano di sicurezza, più preciso ed efficace del precedente

Struttura e contenuti Piano di Sicurezza CIE

Manutenzione ed evoluzione del Piano di Sicurezza

- **Manutenzione ed evoluzione del Piano di Sicurezza**
  - La manutenzione evolutiva deve essere effettuata in considerazione delle schede di monitoraggio previste nella fase Check almeno con una frequenza annuale
  - La manutenzione evolutiva deve essere effettuata al variare:
    - della struttura organizzativa di riferimento
    - del contesto di riferimento
    - delle soluzioni tecnologiche utilizzate ed al livello di sicurezza delle stesse
    - delle minacce e delle vulnerabilità

Struttura e contenuti Piano di Sicurezza CIE

Manutenzione ed evoluzione del Piano di Sicurezza

- **Manutenzione ed evoluzione del Piano di Sicurezza**
  - Il Comune è tenuto a formulare un rapporto che contenga una classificazione delle variazioni del nuovo piano di sicurezza comunale CIE rispetto al precedente, secondo i seguenti parametri:
    - Variazioni della struttura organizzativa, logistica e tecnica
    - Analisi e classificazione dei processi interessati
    - Classificazione minacce, vulnerabilità e valutazione del rischio
    - Variazioni delle procedure operative.

Struttura e contenuti Piano di Sicurezza CIE

Indice del Piano di Sicurezza

- **Indice Piano di Sicurezza**
  - 1 Scopo e campo d'applicazione
  - 2 Riferimenti
  - 3 Definizioni e acronimi
  - 4 Introduzione
  - 5 Descrizione delle norme relative alla "sicurezza"
    6 Politiche di sicurezza e metodologia di attuazione del piano della sicurezza
    7 Descrizione struttura tecnica, logistica ed organizzativa del Comune per l'emissione e l'uso della CIE
    8 Procedure e relativi flussi informativi di emissione ed uso della CIE
    9 Classificazione delle minacce e delle vulnerabilità ai fini della valutazione del rischio
    10 Monitoraggio del piano
    11 Manutenzione ed evoluzione del Piano
    12 Elenco Allegati
    5 Descrizione delle norme relative alla "sicurezza"
  - 6 Politiche di sicurezza e metodologia di attuazione del piano della sicurezza
  - 7 Descrizione struttura tecnica, logistica ed organizzativa del Comune per l'emissione e l'uso della CIE
  - 8 Procedure e relativi flussi informativi di emissione ed uso della CIE